Remote Desktop (RDP) Security Hardening for Windows Endpoints (Intune)

Implementation Solution Guide

Version 1.0.0 · 2026-07-29

Contents

Executive Summary — Remote Desktop (RDP) Security Hardening for Windows Endpoints (Intune) 5

1. Solution Overview — Remote Desktop (RDP) Security Hardening for Windows Endpoints (Intune) 6

- What this solution is . . . 6
- Why RDP defaults are an assessment finding . . . 6
- What this profile configures (the five findings + defense-in-depth) . . . 7
- The one breaking change to respect . . . 8
- How it works, step by step . . . 8
- Benefits . . . 8
- Limitations (be honest with buyers) . . . 8
- The standard deployment model . . . 9

2. Requirements — Remote Desktop (RDP) Security Hardening for Windows Endpoints 9

- R1. Enrolled, managed Windows 10/11 endpoints . . . 9
- R2. Supported Windows baseline . . . 9
- R3. Settings Catalog availability . . . 10
- R4. Inventory of RDP hosts and clients . . . 10
- R5. Legacy-client impact assessment (before High encryption) . . . 10
- R6. The RDP hardening configuration profile . . . 10
- R7. Pilot security group . . . 10
- R8. Admin workstation for the PowerShell scripts (Microsoft Graph) . . . 11
- R9. Awareness of adjacent controls (network + credential) . . . 11
- R10. Pilot device that hosts (or initiates) RDP . . . 11

Global Requirements — Intune Solutions (category-level) 11

- G1. Microsoft Entra ID tenant . . . 11
- G2. Microsoft Intune subscription . . . 11
- G3. Administrative roles . . . 12
- G4. Device enrollment in Intune . . . 12
- G5. Pilot security group . . . 12
- G6. Supported Windows baseline . . . 12
- G7. Network access to Microsoft cloud endpoints . . . 12

3. Implementation — Remote Desktop (RDP) Security Hardening for Windows Endpoints 12

- Phase 1 — Assess and prepare . . . 13
- Phase 2 — Create the RDP hardening profile . . . 13
- Phase 3 — Pilot . . . 15

Phase 4 — Validate and expand . . . 15
5. Testing & Validation — Remote Desktop (RDP) Security Hardening 16
Test 1 — Tenant readiness . . . 16
Test 2 — Profile assignment . . . 17
Test 3 — Profile applied on the device . . . 17
Test 4 — Hardened session behavior (modern client) . . . 17
Test 5 — Legacy-client impact (the breaking-change gate) . . . 17
Test 6 — Remote Assistance disabled . . . 17
Test 7 — Coverage report . . . 17
Test 8 — Reversibility (negative test) . . . 17
Acceptance gate . . . 18
6. Troubleshooting — Remote Desktop (RDP) Security Hardening 18
Symptom: The profile never appears / never applies on the device . . . 18
Symptom: Profile shows "Error" or "Conflict" in Device status . . . 18
Symptom: RDP still lets you in without a password prompt . . . 19
Symptom: Local drives still appear inside the RDP session . . . 19
Symptom: The RDP client can still save the password . . . 19
Symptom: We can no longer RDP to some hosts after enabling High encryption . . . 19
Symptom: Remote Assistance still works . . . 19
Symptom: NLA is not enforced . . . 20
Symptom: Credential-delegation / Restricted Admin behaves unexpectedly . . . 20
Symptom: Coverage report shows fewer devices than the group . . . 20
Escalation checklist . . . 20
7. Best Practices — Remote Desktop (RDP) Security Hardening 20
Pilot the breaking change first . . . 21
One profile, one owner per setting . . . 21
Verify on the device, not just in the portal . . . 21
Harden host and client in the right place . . . 21
Close Remote Assistance deliberately . . . 21
Treat credential and network layers as adjacent projects . . . 22
Operate and monitor . . . 22
Change control . . . 22
8. Deliverables Summary — Remote Desktop (RDP) Security Hardening 22
Documentation (this guide) . . . 22
PowerShell scripts (Microsoft Graph) — `RDPHARD-Scripts.zip` . . . 23
Hero image . . . 24

How it's delivered 24
Appendix A — PowerShell Scripts 25

Executive Summary — Remote Desktop (RDP) Security Hardening for Windows Endpoints (Intune)

Remote Desktop (RDP) is enabled far more widely than most organizations realize, and it ships with defaults that assessments flag every time: weak connection encryption, no forced password prompt, open drive redirection, saved-password convenience, and Solicited Remote Assistance left on. Each is a small door left ajar on every Windows endpoint that can host or initiate an RDP session — and together they are a favorite path for lateral movement and credential exposure. This solution closes those doors with a single, named **Intune Settings Catalog** configuration profile, deployed **pilot-first** and fully reversible.

A deliberately scoped, distinct capability. This is **endpoint-side RDP hardening** for Windows 10/11 devices managed by Intune — it hardens the machine acting as an RDP **host** and, where it initiates outbound RDP, as an RDP **client**. It configures the Remote Desktop Session Host security settings, client-side connection behavior, and Remote Assistance via the Settings Catalog's **Administrative Templates** surface. It is **not** a network/gateway control (no RD Gateway, no firewall rules, no VPN), and the deep **credential-delegation** side (Restricted Admin / Remote Credential Guard as a full credential-theft defense) is cross-referenced to the companion credential-theft hardening solution rather than duplicated here.

This package resolves roughly **five recurring Windows-client assessment findings** in one profile:

- **Client connection encryption level = High (128-bit)** — `MinEncryptionLevel = 3`.
- **Always prompt for password upon connection** — `fPromptForPassword = 1`.
- **Do not allow drive redirection** — `fDisableCdm = 1`.
- **Do not allow passwords to be saved** — `DisablePasswordSaving = 1`.
- **Solicited Remote Assistance = Disabled** — `fAllowToGetHelp = 0` (with Offer Remote Assistance

disabled alongside).

Plus defense-in-depth the same profile carries: **require Network Level Authentication (NLA)** (`UserAuthentication = 1`), a pointer to **Restricted Admin / Remote Credential Guard** for outbound RDP, and guidance to **limit who may log on via RDP**.

This package delivers the complete, field-tested method to stand it up in Intune — written so a single administrator can follow it end to end:

- **One profile, one purpose.** A named `RDP Hardening - Pilot` Settings Catalog profile carrying

the five findings plus NLA, deployed to a pilot group before the fleet.

- **Honest about the one breaking change.** High/128-bit encryption **refuses** legacy clients that

cannot negotiate 128-bit RDP — which is exactly why this is piloted first, with a clear test for legacy-client impact before you expand.

- **Reversible by design.** It only adds a configuration profile; unassigning it cleanly reverts the

endpoints to their prior RDP behavior — no re-imaging, no re-enrollment.

The package follows the standard repeatable shape — **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — with exact, click-by-click Intune steps, a requirements guide that tells you how to verify *and* fix

each prerequisite, five ready-to-run PowerShell scripts (Microsoft Graph), and testing/troubleshooting guides with clear pass/fail gates.

Outcome: every managed Windows endpoint enforces hardened RDP — strong encryption, forced password prompts, no drive redirection, no saved passwords, and Remote Assistance closed — complementing CIS and DISA STIG baselines and proven on a pilot before you scale, without a consulting engagement.

1. Solution Overview — Remote Desktop (RDP) Security Hardening for Windows Endpoints (Intune)

What this solution is

This solution deploys a single, named **Microsoft Intune Settings Catalog** configuration profile that **hardens the Remote Desktop Protocol (RDP)** on **Windows 10/11 endpoints**. It configures the Windows **Remote Desktop Session Host (RDSH)** security settings, the **Remote Desktop Connection Client** behavior, and **Remote Assistance** — the group of settings that vulnerability assessments, CIS Benchmarks, and DISA STIGs repeatedly flag on ordinary workstations because Windows ships them at insecure defaults.

The profile is built entirely from the Settings Catalog's **Administrative Templates** surface (the same ADMX-backed settings you would see in Group Policy), so every setting maps to a well-known registry value you can verify on the device. It is deployed **pilot-first** and is **reversible** by unassigning it.

> ***Scope, stated plainly.*** *This hardens the **endpoint** in both roles it can play in an RDP session: as a **host** (a machine that *accepts* incoming RDP — the RDSH settings) and as a **client** (a machine that *initiates* outbound RDP — saved-password and credential-delegation behavior). It is **not** a network or gateway control — no **RD Gateway**, no firewall/NSG rules, no VPN, no Just-in-Time VM access. The full **credential-theft** defense (Restricted Admin / Remote Credential Guard as a complete anti-lateral-movement program) is **cross-referenced** to the companion credential-theft hardening solution; this product points at the setting and explains its role, but the credential side is owned there to avoid duplication.*

Why RDP defaults are an assessment finding

Every Windows device can host or initiate RDP, and the out-of-box settings are permissive:

- **Encryption is negotiable down to weak levels.** Unless forced to **High (128-bit)**, an RDP host may accept a lower-strength session with a legacy client.
- **The host may not prompt for a password.** With saved or passed credentials, a session can start without an explicit password challenge.
- **Local drives are redirected into the session by default.** That is a data-movement and malware path between the client and the remote host.
- **Passwords can be saved in the RDP client.** A saved credential on a shared or stolen device is a standing risk.

• **Solicited Remote Assistance is available.** It lets a remote helper take control after a user

invitation — useful, but an attack surface that most environments should disable.

Individually minor; together they are the classic "RDP is wide open" cluster that shows up on nearly every Windows-client assessment.

What this profile configures (the five findings + defense-in-depth)

Each setting below is presented by its **Administrative Templates** name (as it appears in the Settings Catalog) and the **registry value** it sets, so you can verify it on the device. Exact Settings Catalog wording is flagged **verify in your tenant** because Microsoft occasionally revises category labels.

The five recurring findings:

1. **Set client connection encryption level = High Level** → `MinEncryptionLevel = 3` (128-bit).

Category: Windows Components → Remote Desktop Services → Remote Desktop Session Host → **Security**.

1. **Always prompt for password upon connection = Enabled** → `fPromptForPassword = 1`.

Category: …Remote Desktop Session Host → **Security**.

1. **Do not allow drive redirection = Enabled** → `fDisableCdm = 1`.

Category: …Remote Desktop Session Host → **Device and Resource Redirection**.

1. **Do not allow passwords to be saved = Enabled** → `DisablePasswordSaving = 1`.

Category: Windows Components → Remote Desktop Services → **Remote Desktop Connection Client**.

1. **Configure Solicited Remote Assistance = Disabled** → `fAllowToGetHelp = 0`; and **Configure

Offer Remote Assistance = Disabled → `fAllowUnsolicited = 0`. ***Category:* System** → Remote Assistance**.

Defense-in-depth carried in the same profile / cross-referenced:

1. **Require user authentication for remote connections by using Network Level Authentication (NLA)

= Enabled** → `UserAuthentication = 1`. NLA forces authentication *before* a full session is established, blunting pre-auth attacks on the RDSH.

1. **Restricted Admin / Remote Credential Guard for outbound RDP** — the *client*-side

credential-delegation setting **Restrict delegation of credentials to remote servers** (`RestrictedRemoteAdministration`). This protects credentials when *this* device connects out to another host. It is the natural companion to endpoint RDP hardening but belongs to the **credential-theft hardening solution** — see the cross-reference note in Implementation. Enabling it has application-compatibility implications (single-sign-on to the remote host changes), so treat it as a deliberate, separately-piloted decision.

1. **Limit who can log on via RDP** — restrict the **Allow log on through Remote Desktop Services**

user right (`SeRemoteInteractiveLogonRight`) to a controlled group rather than the broad default. This solution tells you where and how; the exact user-right surface in the Settings Catalog is flagged **verify in your tenant**.

The one breaking change to respect

Forcing **High / 128-bit** encryption (`MinEncryptionLevel = 3`) means the RDP host will **refuse** any client that cannot negotiate a 128-bit session — genuinely legacy or embedded RDP clients. Modern Windows, macOS, and the current Microsoft Remote Desktop clients all negotiate 128-bit, so the practical blast radius is small, **but it is real** — which is exactly why the whole package is **pilot-first** with an explicit legacy-client test (Testing, Test 5) before you expand.

How it works, step by step

1. **Assess** the environment: confirm which endpoints host or initiate RDP, and identify any legacy RDP clients before you force High encryption.

1. **Configure** one named Settings Catalog profile — `RDP Hardening - Pilot` — carrying the five findings plus NLA.

1. **Pilot** the profile against a small **pilot group** of Windows devices.

2. **Validate** with the included Microsoft Graph scripts (present, assigned, applied) and an on-device RDP connection test (including a legacy-client negative test).

1. **Expand** in waves once the pilot passes, or promote the profile to the standard Windows RDP hardening baseline.

Benefits

• **Resolves ~5 assessment findings at once** — encryption, password prompt, drive redirection, saved passwords, and Remote Assistance, in one profile.

• **Maps to registry values you can verify** — every setting is an ADMX-backed value with a known registry anchor, so "did it apply?" has a definitive answer.

• **Complements CIS / STIG baselines** — a focused, explainable RDP overlay rather than a whole benchmark, so you can layer it cleanly.

• **Reversible and low-risk** — deploys a configuration profile only; unassigning it reverts behavior with no re-imaging or re-enrollment.

• **Pilot-first by design** — the one breaking change (High encryption vs legacy clients) is caught in the pilot, not in production.

Limitations (be honest with buyers)

• **Endpoint-side, not network-side.** This does not deploy RD Gateway, firewall rules, VPN, or JIT VM access. Pair it with your network controls.

• **High encryption denies sub-128-bit legacy clients.** Verified modern clients are fine; genuinely old/embedded clients may be refused — test first.

• **Credential-delegation is cross-referenced, not owned here.** Restricted Admin / Remote Credential Guard is called out and explained, but its full deployment lives in the credential-theft hardening solution.

• **ADMX category wording can change.** The Settings Catalog labels reflect current Microsoft docs — **verify them in your tenant**; the registry anchors are the stable source of truth.

• **Servers vs workstations.** This targets managed **Windows 10/11 client** endpoints via Intune; RDSH session hosts on Windows Server are configured with the same settings but managed differently and are out of scope here.

The standard deployment model

This solution uses **one** repeatable model across our catalog:

> ***Managed Windows 10/11 endpoints receive a single named Settings Catalog profile that hardens RDP — High encryption, forced password prompt, no drive redirection, no saved passwords, Remote Assistance disabled, and NLA required — deployed pilot-first and reversible.***

Every step follows the repeatable pattern: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

2. Requirements — Remote Desktop (RDP) Security Hardening for Windows Endpoints

Confirm **every** requirement below before you begin. Each entry follows the same pattern: **Description · Why required · How to verify · How to implement if missing.** Category-wide prerequisites (tenant, Intune licensing, admin roles, pilot group, network) are covered once in the **Global Requirements — Intune Solutions** document; the items here are specific to hardening RDP on Windows endpoints via the Intune Settings Catalog.

> ***Scope reminder.*** *These requirements are for* ***endpoint-side*** *RDP hardening (host and client behavior) on* ***enrolled, managed Windows 10/11*** *devices. They deliberately do* ***not*** *include network/gateway controls (RD Gateway, firewall, VPN) or the full credential-theft program — those are separate solutions.*

R1. Enrolled, managed Windows 10/11 endpoints

Description: The target devices are Intune-enrolled Windows 10/11 clients (Entra-joined or hybrid-joined). **Why:** The Settings Catalog configuration profile is delivered by Intune MDM and only reaches enrolled, managed devices. **Verify:** Intune admin center (`https://intune.microsoft.com`) → **Devices** → **Windows** → **Windows devices**; the device is listed and **managed**. **Implement:** Enroll the device (Automatic Enrollment on Entra join, or Autopilot) so it appears under **Devices** → **Windows** as managed (Global Requirement G4).

R2. Supported Windows baseline

Description: Windows 10 21H2+ or Windows 11 with current updates on the target endpoints. **Why:** The Administrative Templates / Settings Catalog RDP settings and their CSP delivery assume a patched,

supported Windows client. **Verify:** On the device run `winver`; or Intune → device → **Hardware**. **Implement:** Deploy **Update rings** or upgrade to Windows 11 (Global Requirement G6).

R3. Settings Catalog availability

Description: Access to **Devices** → **Configuration** → **Create** → **New policy** → **Windows 10 and later** → **Settings catalog** in your Intune tenant. **Why:** This solution builds the RDP hardening profile from Settings Catalog **Administrative Templates** settings. **Verify:** In Intune, start **Create** → **New policy** and confirm **Settings catalog** is selectable for **Windows 10 and later**. **Implement:** Settings Catalog is available in all current Intune tenants; if absent, confirm the tenant's Intune licensing (Global Requirement G2) and region.

R4. Inventory of RDP hosts and clients

Description: Knowledge of which endpoints **accept** incoming RDP (hosts) and which **initiate** outbound RDP (clients / admin jump boxes). **Why:** The RDSH settings matter most on hosts; the saved-password and credential-delegation settings matter on clients. Knowing the split lets you target and interpret results correctly. **Verify:** Review your remote-access practice; on a device, RDP-host state is `HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\fDenyTSConnections` (`0` = RDP enabled). The included `RDPHARD-Report.ps1` summarizes coverage across devices. **Implement:** If you do not need a device to host RDP at all, disabling RDP there is stronger than hardening it — note those devices and exclude or separately handle them.

R5. Legacy-client impact assessment (before High encryption)

Description: Confirmation of whether any RDP clients in scope cannot negotiate **128-bit** encryption. **Why:** Setting encryption to **High** (`MinEncryptionLevel = 3`) causes the host to **refuse** sub-128-bit clients. Modern clients are fine; genuinely legacy/embedded clients may break. **Verify:** Identify any old thin clients, embedded RDP clients, or third-party RDP tools that connect to in-scope hosts; test one against a piloted host (Testing, Test 5). **Implement:** Upgrade or replace legacy clients before expanding, or scope those hosts out of the High encryption setting until the clients are remediated.

R6. The RDP hardening configuration profile

Description: A Windows **Settings Catalog** configuration profile named `RDP Hardening - Pilot` carrying the five findings plus NLA. **Why:** This profile is what enforces the hardened RDP settings on the endpoint. **Verify:** Intune → **Devices** → **Configuration**; a profile named `RDP Hardening - Pilot` exists and is assigned to your pilot group. Confirm with `RDPHARD-Discovery.ps1`. **Implement:** Create it during deployment (Implementation Guide, Phase 2), or create/assign it with the included `RDPHARD-Remediation.ps1` (defaults to **-WhatIf** preview).

R7. Pilot security group

Description: A Microsoft Entra security group of pilot **devices** for the first assignment. **Why:** Every solution is validated on a pilot before fleet rollout; RDP hardening includes a breaking-change setting (High encryption) that must be piloted. **Verify:** Entra → **Groups**; the pilot device group exists (Global Requirement G5). **Implement:** Entra → **Groups** → **New group** → **Security**; add the pilot devices. Assign the profile to this group (Implementation Step 7 / `RDPHARD-Set-ScopeTargeting.ps1`).

R8. Admin workstation for the PowerShell scripts (Microsoft Graph)

Description: A workstation with **PowerShell 7+** and the **Microsoft Graph PowerShell SDK** installed, run by an operator with Intune admin rights. **Why:** The five included scripts validate and remediate the profile through Microsoft Graph. **Verify:** `Get-Module -ListAvailable Microsoft.Graph.Authentication` returns a version; the operator can `Connect-MgGraph`. **Implement:** `Install-Module Microsoft.Graph -Scope CurrentUser`. Read-only scripts need `DeviceManagementConfiguration.Read.All` (Report also needs `DeviceManagementManagedDevices.Read.All`); change-making scripts need `DeviceManagementConfiguration.ReadWrite.All`.

R9. Awareness of adjacent controls (network + credential)

Description: Awareness that this solution is the **endpoint** layer and pairs with network-side and credential-side controls. **Why:** Hardened RDP settings on the endpoint do not replace an RD Gateway, network segmentation, or a full credential-theft program (Restricted Admin / Remote Credential Guard). Setting expectations prevents "we hardened RDP but exposure X remains" gaps. **Verify:** Confirm your RD Gateway / firewall posture and whether the credential-theft hardening solution is (or will be) deployed for the credential-delegation side. **Implement:** Deploy the network controls separately; deploy the credential-theft hardening solution for Restricted Admin / Remote Credential Guard (cross-referenced in Implementation, Phase 4).

R10. Pilot device that hosts (or initiates) RDP

Description: At least one enrolled pilot Windows device that actually **accepts** incoming RDP (and, ideally, one that **initiates** it), so silent-vs-breaking behavior is observable. **Why:** You cannot validate encryption, password-prompt, redirection, and Remote Assistance behavior on a device that never sees an RDP session. **Verify:** On the pilot host, `fDenyTSConnections = 0` (RDP enabled); you can initiate an RDP session to it from a test client. **Implement:** Add the pilot host/client to the **pilot security group** (R7) used for the profile assignment, and confirm you can reach it over RDP from a controlled test client.

Global Requirements — Intune Solutions (category-level)

These requirements apply to **every** solution in the **Intune Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Intune solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID (Azure AD) tenant. **Why:** It is the identity backbone for every cloud and Intune-managed resource. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator. **Implement:** Create a Microsoft 365/Azure subscription, which provisions a tenant.

G2. Microsoft Intune subscription

Description: An Intune-bearing license plan. **Why:** Intune delivers all configuration, compliance, and security policies. **Verify:** `https://intune.microsoft.com` loads; **Tenant administration** → **Tenant**

status shows active. **Implement:** Assign Microsoft 365 E3/E5, Business Premium, or standalone Intune Plan 1.

G3. Administrative roles

Description: Appropriate Entra/Intune admin roles for the operator. **Why:** Creating policies and enrollment settings requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Intune Administrator**. **Implement:** Assign **Intune Administrator**; reserve Global Administrator for tenant-wide changes.

G4. Device enrollment in Intune

Description: Targeted Windows devices are enrolled and manageable. **Why:** Policies only reach enrolled devices. **Verify:** Intune → **Devices** → **All devices**; the device appears and is **compliant**. **Implement:** Enable **Automatic Enrollment** and join devices to Entra ID.

G5. Pilot security group

Description: A Microsoft Entra security group for pilot/targeted users or devices. **Why:** Every solution is piloted before fleet rollout. **Verify:** Entra → **Groups**; the pilot group exists. **Implement:** Entra → **Groups** → **New group** → **Security** → add members.

G6. Supported Windows baseline

Description: Windows 10 21H2+ or Windows 11 with current updates. **Why:** Modern Intune features assume a patched, supported OS. **Verify:** `winver`, or Intune → device → **Hardware**. **Implement:** Deploy **Update rings** or upgrade to Windows 11.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365, Entra, and Intune service URLs. **Why:** Enrollment, policy sync, and authentication depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://enrollment.manage.microsoft.com`. **Implement:** Allow Microsoft's published Office 365/Intune URL & IP ranges through proxy/firewall.

The standard deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

3. Implementation — Remote Desktop (RDP) Security Hardening for Windows Endpoints

Follow these steps **in order**. The *why* for each capability lives in the Solution Overview; the steps below are deliberately short and exact so you can **click to implement**. Throughout, the repeatable pattern applies: **Assess → Configure → Pilot → Validate → Expand.** Do everything against a **pilot group** first — one of these settings (High encryption) is a breaking change.

All admin-center steps use the Microsoft Intune admin center at `https://intune.microsoft.com` unless noted.

> ***This deploys endpoint-side RDP hardening only*** *on* ***enrolled, managed*** *Windows 10/11 devices. It does not deploy RD Gateway, firewall, or VPN, and it does not own the credential-theft program. Every setting below is an* ***Administrative Templates*** *setting delivered through the* ***Settings Catalog****, mapped to a known registry value so you can verify it on the device.*

Phase 1 — Assess and prepare

Step 1. Confirm enrollment, Windows baseline, and RDP posture

1. Go to **Devices** → **Windows** → **Windows devices** and confirm the pilot device is **managed**.
2. Open the device → **Hardware** and confirm Windows 10 21H2+ or Windows 11 (current updates).
3. Identify which pilot devices **host** RDP (`fDenyTSConnections = 0`) and which **initiate** it. The included `RDPHARD-Report.ps1` helps summarize this across devices.

Step 2. Identify legacy RDP clients (the one breaking change)

1. Before forcing **High / 128-bit** encryption, list any RDP clients that connect to in-scope hosts — old thin clients, embedded clients, third-party RDP tools.
1. Plan to test one legacy client against a piloted host (Testing, Test 5). Modern Windows/macOS and current Microsoft Remote Desktop clients negotiate 128-bit; genuinely old clients may be refused.

Step 3. Confirm your pilot device group

1. In **Entra** → **Groups**, confirm a **security group of pilot devices** exists (Global Requirement G5 / R7). You will assign the profile to this group in Step 7.

Phase 2 — Create the RDP hardening profile

Step 4. Create the Settings Catalog profile

1. Go to **Devices** → **Configuration** → **Create** → **New policy**.
2. **Platform** = **Windows 10 and later**; **Profile type** = **Settings catalog**. Click **Create**.
3. **Basics** → **Name:** `RDP Hardening - Pilot`. Add a description, e.g. *Endpoint RDP hardening — High encryption, always prompt for password, no drive redirection, no saved passwords, Remote Assistance disabled, NLA required.* Click **Next**.

Step 5. Add the five finding settings (plus NLA)

On **Configuration settings**, click **Add settings** and use the settings picker to search each category below, then set the value shown. The **registry value** each one writes is given so you can verify on the device; the exact Settings Catalog label wording is **verify in your tenant** (Microsoft occasionally revises category labels — the registry anchor is the stable truth).

Category — Administrative Templates → Windows Components → Remote Desktop Services → Remote Desktop Session Host → Security:

- **Set client connection encryption level** = **Enabled**, Encryption Level = **High Level** → `MinEncryptionLevel = 3` (128-bit). *(This is the breaking-change setting — pilot first.)*
- **Always prompt for password upon connection** = **Enabled** → `fPromptForPassword = 1`.
- **Require user authentication for remote connections by using Network Level Authentication** = **Enabled** → `UserAuthentication = 1`.

Category — …Remote Desktop Session Host → Device and Resource Redirection:

- **Do not allow drive redirection** = **Enabled** → `fDisableCdm = 1`.

Category — Administrative Templates → Windows Components → Remote Desktop Services → Remote Desktop Connection Client:

- **Do not allow passwords to be saved** = **Enabled** → `DisablePasswordSaving = 1`.

Category — Administrative Templates → System → Remote Assistance:

- **Configure Solicited Remote Assistance** = **Disabled** → `fAllowToGetHelp = 0`.
- **Configure Offer Remote Assistance** = **Disabled** → `fAllowUnsolicited = 0`.

> ***Tip.*** *In the Settings Catalog picker, search the exact phrase (e.g. *"Always prompt for password upon connection"*) and confirm the* ***category path*** *shown matches the one above before selecting — several similarly-named RDP settings exist. Keep a short table (setting → value → registry anchor) as your record.*

Step 6. Decide on the defense-in-depth extras (deliberate, may be separate)

These are the two items the Overview cross-references. Add them **only** with intent:

- **Restricted Admin / Remote Credential Guard for outbound RDP** — the client-side **Restrict delegation of credentials to remote servers **setting (`RestrictedRemoteAdministration`, under *Administrative Templates → System → Credentials Delegation*). This protects credentials when this device connects** out **to another host, but changes single-sign-on behavior to the remote host.** Its full deployment belongs to the credential-theft hardening solution** — deploy it there, separately piloted, rather than folding it into this profile. If you do include it here, pilot it on its own.
- **Limit who can log on via RDP** — restrict the **Allow log on through Remote Desktop Services** user right (`SeRemoteInteractiveLogonRight`) to a controlled group instead of the broad default. The exact user-rights surface in the Settings Catalog is **verify in your tenant**; if it is not exposed as a Settings Catalog setting in your tenant, apply it via an Account Protection / security-baseline policy or a User Rights Assignment setting and reference the same named group.

Step 7. Scope tags, assignment, review

1. **Next** through **Scope tags** (set if you use them).
2. **Assignments:** add the **pilot device group** (R7). Do **not** assign to "All devices" yet. Click **Next**.
1. **Review + create** → **Create**.

Prefer automation? Run the included `RDPHARD-Set-ScopeTargeting.ps1` *(Microsoft Graph) to set or adjust the assignment (defaults to* ***-WhatIf*** *— preview first, then re-run to apply), and* `RDPHARD-Discovery.ps1` *to confirm the profile is present with the expected settings.*

Phase 3 — Pilot

Step 8. Push and confirm the profile

1. On the pilot device, sync Intune (**Settings → Accounts → Access work or school → (account) → Info →

Sync**, or `dsregcmd /refreshprt` then a policy sync).

1. In Intune → **Devices** → **Configuration** → `RDP Hardening - Pilot` → **Device status**, confirm the pilot

device shows **Succeeded**.

1. *(Optional device-side proof)* On the pilot host, confirm the registry values, e.g.

`reg query "HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services" /v MinEncryptionLevel` returns 3, and `fPromptForPassword`, `fDisableCdm`, `fAllowToGetHelp` are set as intended.

Step 9. Verify hardened behavior with a live RDP session

1. From a **modern** test client, initiate an RDP session to the pilot host.
2. Confirm the session **prompts for a password** (`fPromptForPassword`), that **local drives do not

appear **inside the session (**`fDisableCdm`**), and that the client** cannot save** the password (`DisablePasswordSaving`).

1. Confirm the session negotiates a 128-bit-capable connection (High encryption) and that **NLA** is

enforced (the client authenticates before the full session appears).

Step 10. Confirm Remote Assistance is closed

1. Attempt to launch **Solicited Remote Assistance** on the pilot device (e.g. `msra.exe /novice`).
2. Confirm it is **blocked/disabled** (`fAllowToGetHelp = 0`), and that unsolicited/offer Remote

Assistance is likewise disabled (`fAllowUnsolicited = 0`).

Phase 4 — Validate and expand

Step 11. Validate with the scripts

1. Run `RDPHARD-Discovery.ps1` (tenant readiness: the `RDP Hardening - Pilot` Settings Catalog

profile is present and carries the expected RDP settings).

1. Run `RDPHARD-Validation.ps1` to confirm the profile is **assigned** to the intended group and the

pilot device shows the profile **applied**.

1. Run `RDPHARD-Report.ps1` to produce a coverage report (which Windows devices have the RDP hardening profile applied).

Step 12. Remediate gaps (safe by default)

1. If devices are missing or mis-scoped, run `RDPHARD-Remediation.ps1` — it **defaults to** `-WhatIf` and prints exactly what it would create/assign. Review, then re-run with `-WhatIf:$false` to apply.

Step 13. Address the credential and network layers (cross-reference)

1. Deploy the **credential-theft hardening solution** for **Restricted Admin / Remote Credential Guard** (the credential-delegation side of outbound RDP) — pilot it separately.

1. Confirm your **network-side** RDP controls (RD Gateway, firewall/NSG rules, VPN, JIT VM access) are in place; this endpoint profile complements but does not replace them.

Step 14. Expand in waves

1. Once the pilot passes (Testing gate) **including the legacy-client test**, broaden the profile assignment to the next device group, or make it the standard Windows RDP hardening baseline.

1. Roll out in waves, validating each wave with `RDPHARD-Report.ps1` before widening — and re-checking the legacy-client impact (R5) for each new population.

5. Testing & Validation — Remote Desktop (RDP) Security Hardening

Validate against a **pilot device** before expanding. Each test has an explicit **pass/fail gate**. Use the included PowerShell scripts (Microsoft Graph) for tenant-side checks and the on-device steps for the enforced behavior. Test 5 is the **legacy-client** test — the one that gates expansion because High encryption is a breaking change.

> ***What "pass" means here:*** *the managed Windows endpoint enforces the five hardened RDP settings (High encryption, always prompt for password, no drive redirection, no saved passwords, Remote Assistance disabled) plus NLA, verifiable both in Intune and on the device — and legacy-client impact is known before you widen.*

Test 1 — Tenant readiness

Procedure: Run `RDPHARD-Discovery.ps1`. **Pass:** A Settings Catalog profile named `RDP Hardening - Pilot` exists and reports the expected RDP settings present (encryption, password prompt, drive redirection, saved passwords, Remote Assistance, NLA). **Fail:** Missing profile or missing settings → create/complete it (Implementation Phase 2 / `RDPHARD-Remediation.ps1`).

Test 2 — Profile assignment

Procedure: Run `RDPHARD-Validation.ps1` (or check **Devices** → **Configuration** → `RDP Hardening - Pilot` → **Assignments**). **Pass:** The profile is assigned to the intended **pilot device group** and to no unintended broad group. **Fail:** Not assigned, or assigned to "All devices" prematurely → correct the assignment (Implement Step 7 / `RDPHARD-Set-ScopeTargeting.ps1`).

Test 3 — Profile applied on the device

Procedure: On the pilot device, sync Intune, then check **Devices** → **Configuration** → `RDP Hardening - Pilot` → **Device status**. Optionally verify the registry values on the device. **Pass:** The profile shows **Succeeded**, and on the device `HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\MinEncryptionLevel = 3`, `fPromptForPassword = 1`, `fDisableCdm = 1`, `fAllowToGetHelp = 0`, `UserAuthentication = 1`, and `DisablePasswordSaving = 1` (Remote Desktop Connection Client key). **Fail:** Not applied / error → force a sync and re-check; resolve conflicts (Troubleshooting).

Test 4 — Hardened session behavior (modern client)

Procedure: From a **modern** RDP client, connect to the pilot host. **Pass:** The session **prompts for a password**, **local drives are not redirected** into the session, the client **cannot save** the password, **NLA** authenticates before the session appears, and the connection succeeds at 128-bit (High) encryption. **Fail:** Password not prompted, drives visible, password savable, or NLA not enforced → re-check the corresponding setting in the profile (Step 5) and that the device applied it (Test 3).

Test 5 — Legacy-client impact (the breaking-change gate)

Procedure: From a **legacy / embedded** RDP client that cannot negotiate 128-bit (or a deliberately downgraded test), attempt to connect to the piloted host. **Pass (expected):** The host **refuses** the sub-128-bit client — this **confirms** High encryption is enforcing. Record which clients are affected. **Interpretation:** This is the intended behavior, not a defect. **Do not expand** until every legacy client that must reach in-scope hosts is upgraded/replaced, or those hosts are scoped out of the High encryption setting until the clients are remediated (R5).

Test 6 — Remote Assistance disabled

Procedure: On the pilot device, attempt to launch **Solicited Remote Assistance** (e.g. `msra.exe /novice`). **Pass:** Solicited Remote Assistance is **blocked/disabled** (`fAllowToGetHelp = 0`); Offer Remote Assistance is likewise disabled (`fAllowUnsolicited = 0`). **Fail:** Remote Assistance still launches → confirm both Remote Assistance settings are **Disabled** in the profile (Step 5) and applied (Test 3).

Test 7 — Coverage report

Procedure: Run `RDPHARD-Report.ps1`. **Pass:** The report lists the pilot device(s) as **profile applied**; counts match the assigned group. **Fail:** Devices missing from the report → run `RDPHARD-Remediation.ps1` (`-WhatIf` first) to fix assignment/scoping, then re-sync stragglers.

Test 8 — Reversibility (negative test)

Procedure: On a spare pilot device, unassign the `RDP Hardening - Pilot` profile and re-sync. **Pass:** The endpoint cleanly reverts to its prior RDP behavior (the policy registry values are removed) with **no re-imaging and no re-enrollment** — confirming the change is reversible by unassignment. **Fail:** Behavior does not revert → confirm no second profile or a security baseline is also setting these values (Troubleshooting: conflicts).

Acceptance gate

Proceed to **Expand** only when Tests 1–4, 6, and 7 pass on at least one pilot device, **Test 5 confirms the legacy-client impact is known and acceptable**, and Test 8 confirms the change is reversible. Widen in waves, re-checking legacy-client impact for each new population.

6. Troubleshooting — Remote Desktop (RDP) Security Hardening

Work top-down: confirm the **profile is applied**, then **the specific setting is present and correct**, then **conflicts**. Most "it didn't harden" cases are a device that hasn't synced, a setting picked from the wrong category, or a second policy/baseline setting the same value. Most "we broke RDP" cases are the expected High-encryption legacy-client refusal. Each symptom below gives the **likely cause** and the **fix**.

> ***Before you start:*** *verify which problem you have. A device that* ***refuses an old RDP client*** *after this profile is working *as designed* (High encryption) — that is Test 5, not a fault. A device where the* ***settings never took*** *is a delivery/scoping problem — start at the top.*

Symptom: The profile never appears / never applies on the device

Likely cause: Device not synced, not assigned, or not enrolled. **Fix:**

1. Confirm the device is in the **pilot device group** and the profile is **assigned**

(`RDPHARD-Validation.ps1`).

1. Force an Intune sync (**Settings** → **Accounts** → **Access work or school** → **Sync**) and re-check

Devices → **Configuration** → `RDP Hardening - Pilot` → **Device status**.

1. Confirm the device is **managed** (R1) and on a supported Windows build (R2).

Symptom: Profile shows "Error" or "Conflict" in Device status

Likely cause: A second Settings Catalog profile, a **security baseline** (CIS/STIG), or a legacy Administrative Templates (ADMX) profile sets the same RDP value to a different setting. **Fix:**

1. Run `RDPHARD-Discovery.ps1` and review other Windows configuration profiles/baselines.
2. Ensure only **one** source sets each RDP value (e.g. `MinEncryptionLevel`, `fDisableCdm`); remove or

reconcile the duplicate. When this overlays a CIS/STIG baseline, decide which policy owns the setting and remove it from the other.

1. Re-sync and re-check Device status.

Symptom: RDP still lets you in without a password prompt

Likely cause: `fPromptForPassword` not applied, or credentials are being passed by the client (NLA single-sign-on) so no interactive prompt appears. **Fix:**

1. Confirm **Always prompt for password upon connection = Enabled** in the profile (Step 5) and applied

on the device (`fPromptForPassword = 1`, Test 3).

1. Test with a client that is not passing saved/SSO credentials; NLA can authenticate silently up front

while the host still enforces the in-session password prompt — validate the intended behavior rather than assuming a failure.

Symptom: Local drives still appear inside the RDP session

Likely cause: `fDisableCdm` not applied, or the setting was picked from the wrong category. **Fix:**

1. Confirm **Do not allow drive redirection = Enabled** under **Device and Resource Redirection**

(not a different redirection setting) — Step 5.

1. Verify on the device (`fDisableCdm = 1`) and reconnect a fresh RDP session (existing sessions keep

their redirection until reconnect).

Symptom: The RDP client can still save the password

Likely cause: `DisablePasswordSaving` not applied, or it was set only on the host, not the client. **Fix:**

1. `DisablePasswordSaving` is a **Remote Desktop Connection Client** setting — it must be applied on the

initiating (client) device, not only the host (R4).

1. Confirm the client device is in scope and shows the profile applied (`DisablePasswordSaving = 1`).

Symptom: We can no longer RDP to some hosts after enabling High encryption

Likely cause: Expected — those clients cannot negotiate 128-bit and the host now refuses them (`MinEncryptionLevel = 3`). **Fix:**

1. This is Test 5 behaving correctly. Identify the legacy/embedded clients (R5) and **upgrade or

replace** them.

1. If a host must keep serving a legacy client temporarily, scope that host **out** of the High

encryption setting until the client is remediated — do not weaken it fleet-wide.

Symptom: Remote Assistance still works

Likely cause: Only one Remote Assistance setting was disabled, or another policy re-enables it. **Fix:**

1. Confirm **both Configure Solicited Remote Assistance = Disabled** (`fAllowToGetHelp = 0`) and **Configure Offer Remote Assistance = Disabled** (`fAllowUnsolicited = 0`) — Step 5.
1. Check for a competing GPO/baseline re-enabling Remote Assistance and reconcile ownership.

Symptom: NLA is not enforced

Likely cause: `UserAuthentication` not applied, or the OS/edition negotiated a fallback. **Fix:**

1. Confirm **Require user authentication … using Network Level Authentication = Enabled** (`UserAuthentication = 1`) — Step 5 — and applied on the host (Test 3).
1. Re-check on a supported Windows build (R2); force a sync.

Symptom: Credential-delegation / Restricted Admin behaves unexpectedly

Likely cause: Restricted Admin / Remote Credential Guard is out of scope for this profile and is owned by the credential-theft hardening solution. **Fix:**

1. Do not troubleshoot `RestrictedRemoteAdministration` here — this profile hardens the endpoint's RDP settings, not the full credential-delegation program.
1. See the **credential-theft hardening solution** (cross-referenced, Implementation Step 13) for that setting's deployment and troubleshooting.

Symptom: Coverage report shows fewer devices than the group

Likely cause: Some devices not synced, not enrolled, or superseded by a conflicting profile. **Fix:**

1. Run `RDPHARD-Report.ps1` to list which devices lack the applied profile.
2. Run `RDPHARD-Remediation.ps1` **(`-WhatIf` first)** to correct assignment/scoping.
3. Re-sync stragglers and confirm enrollment (R1) and no conflicting policy (conflicts above).

Escalation checklist

Before opening a Microsoft support case, collect: the `RDPHARD-Discovery.ps1` output, the profile's Device status export, the on-device registry values for the six RDP settings, the affected client type/version (for legacy-client refusals), the Windows build, and whether any CIS/STIG baseline also targets RDP (isolates a conflict from a delivery problem).

7. Best Practices — Remote Desktop (RDP) Security Hardening

These practices keep the endpoint RDP hardening precise, predictable, and reversible on managed Windows 10/11 devices. They assume the deployment model in the Solution Overview: one named

Settings Catalog profile (`RDP Hardening - Pilot`) built from Administrative Templates settings, deployed via Intune, pilot-first.

Pilot the breaking change first

- **High encryption is the one setting that can break access.** `MinEncryptionLevel = 3` refuses sub-128-bit clients. Always run the **legacy-client test** (Testing, Test 5) on a piloted host before widening, and keep a list of any clients that must be upgraded.
- **Assign to a pilot device group, never "All devices" first.** Expand in waves only after each gate passes, and re-check legacy-client impact for each new population.

One profile, one owner per setting

- **Keep all five findings plus NLA in the single** `RDP Hardening - Pilot` **profile** so the RDP posture is in one place, named, and easy to audit — every test and troubleshooting step refers back to it.
- **Avoid double-setting.** If a CIS or STIG baseline already sets an RDP value, decide which policy **owns** it and remove it from the other — two sources setting the same value is the most common "Conflict" in Device status.
- **Record each setting's registry anchor.** Keep a short table (setting → value → registry value name) so the next admin can verify on the device without guessing.

Verify on the device, not just in the portal

- **Trust the registry, confirm the labels.** The Settings Catalog category wording can change; the registry anchors (`MinEncryptionLevel`, `fPromptForPassword`, `fDisableCdm`, `DisablePasswordSaving`, `fAllowToGetHelp`, `UserAuthentication`) do not. Verify the values on a pilot device as the definitive proof it applied.
- **Test a live RDP session,** not only Device status = Succeeded. Password prompt, no drive redirection, no saved password, and NLA are only truly proven from a real connection (Test 4).

Harden host and client in the right place

- **Host-side settings on hosts; client-side on clients.** The RDSH settings (encryption, prompt, redirection, NLA) matter on machines that **accept** RDP; `DisablePasswordSaving` matters on machines that **initiate** it. Scope so each population actually receives the settings that apply to it (R4).
- **If a device never needs to host RDP, disable RDP there** rather than merely hardening it — a disabled listener is a smaller surface than a hardened one.

Close Remote Assistance deliberately

- **Disable both Solicited and Offer Remote Assistance** unless you have a specific, controlled support

workflow that needs it. If you keep it for a helpdesk, scope it narrowly and document the exception.

Treat credential and network layers as adjacent projects

- **Restricted Admin / Remote Credential Guard is the credential-theft solution's job.** Cross-reference

it, pilot it separately (it changes single-sign-on to the remote host), and don't fold it into this profile by default.

- **Pair with network controls.** Endpoint hardening complements — never replaces — RD Gateway,

firewall/NSG rules, VPN, and JIT VM access. State this to stakeholders so "RDP is hardened" isn't mistaken for "RDP is off the internet."

Operate and monitor

- **Report before you widen.** Run `RDPHARD-Report.ps1` each wave; only broaden when coverage matches

the assigned group.

- **Remediate with `-WhatIf` first.** `RDPHARD-Remediation.ps1` and `RDPHARD-Set-ScopeTargeting.ps1`

preview by default — read the plan, then apply with `-WhatIf:$false`.

- **Rollback is unassignment.** Because this only adds a configuration profile, removing the assignment

cleanly reverts behavior (Test 8) — no enrollment or image cleanup needed. Keep the profile so you can re-target quickly.

Change control

- **Version scope changes.** When you add a setting, change the encryption level, or adjust the assigned

group, note the date and reason; re-run Discovery and Report to confirm no regressions.

- **Review after Windows feature updates and baseline changes.** Confirm the RDP settings still apply and

that a newly imported CIS/STIG baseline hasn't started competing for the same values before expanding.

8. Deliverables Summary — Remote Desktop (RDP) Security Hardening

Everything included in this solution package, and what each piece is for.

Documentation (this guide)

- **Executive Summary** — the business case and outcome in one page, and the explicit scope: endpoint

RDP hardening for Windows 10/11 via Intune, resolving ~5 assessment findings — not network/gateway controls, and not the full credential-theft program.

- **Solution Overview** — why RDP defaults are an assessment finding, the five findings plus NLA and

the cross-referenced credential/logon extras, each mapped to its registry anchor, and the one breaking change (High encryption vs legacy clients).

- **Requirements Guide** — every Intune/Windows/Settings-Catalog prerequisite with how to **verify** and

how to **implement if missing**, including the legacy-client impact assessment, plus the category-level Global Requirements.

- **Implementation Guide** — exact, ordered, click-by-click steps across four phases: assess and prepare

(including legacy-client identification), build the named `RDP Hardening - Pilot` Settings Catalog profile, pilot with a live RDP session, then validate and expand.

- **Testing & Validation** — eight tests with explicit pass/fail gates, including the legacy-client

breaking-change gate and a reversibility negative test, and an acceptance gate.

- **Troubleshooting** — top-down diagnosis for "it didn't harden," conflicts with CIS/STIG baselines,

the expected legacy-client refusal, and each per-setting symptom.

- **Best Practices** — pilot the breaking change first, one owner per setting, verify on the device,

harden host vs client in the right place, and treat credential/network layers as adjacent projects.

PowerShell scripts (Microsoft Graph) — `RDPHARD-Scripts.zip`

All scripts are tenant-side (run from an admin workstation with the Microsoft Graph PowerShell SDK); each has a header explaining **Purpose · How to run · Expected results**. Discovery, Validation, and Report are **read-only**; Remediation and Set-ScopeTargeting **default to** `-WhatIf` (preview first, then apply).

1. `RDPHARD-Discovery.ps1` — tenant readiness: the `RDP Hardening - Pilot` Settings Catalog profile

is present and carries the expected RDP settings (encryption, password prompt, drive redirection, saved passwords, Remote Assistance, NLA).

1. `RDPHARD-Validation.ps1` — validates the profile's **assignment** and per-device **applied**

state, with a clear PASS/FAIL summary.

1. `RDPHARD-Report.ps1` — tenant-wide CSV report of Windows devices and whether the RDP hardening

profile is applied — the coverage report.

1. `RDPHARD-Remediation.ps1` — safe remediation of a missing/mis-scoped profile (create the Settings

Catalog profile if absent, assign it to a target group). `-WhatIf` **by default**; applies only when re-run with `-WhatIf:$false`.

1. `RDPHARD-Set-ScopeTargeting.ps1` — sets/adjusts the profile's group assignment (target-group

builder, with optional exclusion group). `-WhatIf` **by default.**

Hero image

- `RDPHARD-hero.png` — the product image used on the marketplace listing.

How it's delivered

A **Word** document and **PDF** (cover, table of contents, page numbers, and a scripts appendix), plus all five PowerShell scripts in a single **ZIP** — yours to keep and reuse across **unlimited devices**.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

RDPHARD-Discovery.ps1

Purpose: Confirms the Intune tenant is ready to enforce endpoint RDP hardening on Windows 10/11: a Settings Catalog configuration profile (default name 'RDP Hardening - Pilot') exists and carries the expected Remote Desktop settings — client connection encryption level High/128-bit (MinEncryptionLevel), always prompt for password (fPromptForPassword), do not allow drive redirection (fDisableCdm), do not allow saved passwords (DisablePasswordSaving), Solicited/Offer Remote Assistance disabled (fAllowToGetHelp / fAllowUnsolicited), and Network Level Authentication required (UserAuthentication). Reports which settings are present so gaps are visible before piloting. This checks the ENDPOINT RDP hardening profile only — not network / gateway controls and not the credential-theft (Restricted Admin / Remote Credential Guard) program. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\RDPHARD-Discovery.ps1 Optional: -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. A READY tenant shows a Windows Settings Catalog RDP hardening profile present with the expected RDP settings detected. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot')

How to run: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Discovery.ps1 Optional: -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. A READY tenant shows a Windows Settings Catalog RDP hardening profile present with the expected RDP settings detected. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot')

RDPHARD-Remediation.ps1

Purpose: Remediates the common gaps that leave endpoint RDP hardening undeployed on managed Windows devices: if the RDP hardening Settings Catalog profile exists but is not assigned to the intended group, it (re)assigns it; if no RDP hardening profile exists at all, it reports exactly what the guide's profile must contain and does NOT invent one. Defaults to -WhatIf, so it previews every change and modifies nothing until re-run with -WhatIf:$false. Remediates the endpoint RDP hardening profile's ASSIGNMENT only — it does not author the RDP setting values (those are built in Intune per Implementation Phase 2, because the exact Settings Catalog / ADMX setting identifiers are tenant-verifiable) and it never touches network controls or the credential-theft program. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\RDPHARD-Remediation.ps1 -GroupId your-entra-group-object-id Apply the change: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Remediation.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: a report of what is missing and exactly what WOULD be assigned (or the settings the guide's profile must carry, if the profile is absent). When applied: the RDP hardening profile is assigned to the target group. Re-run RDPHARD-Discovery.ps1 / RDPHARD-Validation.ps1 to confirm. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)]

param([Parameter(Mandatory)] [string]$GroupId, [string]$ProfileName = 'RDP Hardening - Pilot')

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\RDPHARD-Remediation.ps1 -GroupId your-entra-group-object-id Apply the change: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Remediation.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: a report of what is missing and exactly what WOULD be assigned (or the settings the guide's profile must carry, if the profile is absent). When applied: the RDP hardening profile is assigned to the target group. Re-run RDPHARD-Discovery.ps1 / RDPHARD-Validation.ps1 to confirm. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$ProfileName = 'RDP Hardening - Pilot')

RDPHARD-Report.ps1

Purpose: Produces a coverage report across managed Windows devices: for each device, whether the RDP security-hardening Settings Catalog profile is applied. Use it to measure coverage before widening a rollout and to find endpoints still missing the hardened RDP settings. Read-only. Reports the endpoint RDP hardening profile only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\RDPHARD-Report.ps1 Optional: -ProfileName "RDP Hardening - Pilot" -CsvPath .\RDPHARD-coverage.csv (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All EXPECTED RESULTS A table (and optional CSV) of Windows devices with an Applied column (Yes/No/Error) plus a coverage summary. Full coverage = every intended device shows Applied = Yes. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot', [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Report.ps1 Optional: -ProfileName "RDP Hardening - Pilot" -CsvPath .\RDPHARD-coverage.csv (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All, DeviceManagementManagedDevices.Read.All EXPECTED RESULTS A table (and optional CSV) of Windows devices with an Applied column (Yes/No/Error) plus a coverage summary. Full coverage = every intended device shows Applied = Yes. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot', [string]$CsvPath)

RDPHARD-Set-ScopeTargeting.ps1

Purpose: Sets or adjusts which Entra security group the RDP security-hardening Settings Catalog profile is assigned to — the target-group builder for pilot-first, wave-based rollout on Windows endpoints. Optionally adds an assignment exclusion group. Defaults to -WhatIf, previewing the assignment change and modifying nothing until re-run with -WhatIf:$false. Targets the endpoint RDP hardening profile only, not network controls or the credential-theft program. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\RDPHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id Apply the assignment: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ExcludeGroupId your-exclusion-group-object-id ; -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes:

DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: the profile found and the assignment that WOULD be set. When applied: the profile is assigned to the include group (and excludes the exclusion group). Confirm in Intune - Devices - Configuration, or with RDPHARD-Validation.ps1. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$ExcludeGroupId, [string]$ProfileName = 'RDP Hardening - Pilot')

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\RDPHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id Apply the assignment: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Set-ScopeTargeting.ps1 -GroupId your-entra-group-object-id -WhatIf:$false Optional: -ExcludeGroupId your-exclusion-group-object-id ; -ProfileName "RDP Hardening - Pilot" (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.ReadWrite.All EXPECTED RESULTS In preview: the profile found and the assignment that WOULD be set. When applied: the profile is assigned to the include group (and excludes the exclusion group). Confirm in Intune - Devices - Configuration, or with RDPHARD-Validation.ps1. .NOTES White-label — the repeatable way. Defaults to -WhatIf; changes require -WhatIf:$false. > [CmdletBinding(SupportsShouldProcess)] param([Parameter(Mandatory)] [string]$GroupId, [string]$ExcludeGroupId, [string]$ProfileName = 'RDP Hardening - Pilot')

RDPHARD-Validation.ps1

Purpose: Validates the Windows RDP security-hardening Settings Catalog profile is assigned to the intended group and applied on target devices. Confirms the profile exists, that it is assigned (optionally to a specified group), and reports each Windows device's applied state (Succeeded / Error / Not applied). Read-only. Validates the endpoint RDP hardening profile only, not network controls or the credential-theft program. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\RDPHARD-Validation.ps1 -ProfileName "RDP Hardening - Pilot" Optional: -GroupId your-entra-group-object-id (assert the profile is assigned to this group) (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL summary: profile found, assigned (to -GroupId if supplied), and a per-device applied-state table. PASS when the profile is assigned and pilot devices report Succeeded. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot', [string]$GroupId)

How to run: powershell -ExecutionPolicy Bypass -File .\RDPHARD-Validation.ps1 -ProfileName "RDP Hardening - Pilot" Optional: -GroupId your-entra-group-object-id (assert the profile is assigned to this group) (Install once: Install-Module Microsoft.Graph -Scope CurrentUser) Required Graph scopes: DeviceManagementConfiguration.Read.All EXPECTED RESULTS A PASS/FAIL summary: profile found, assigned (to -GroupId if supplied), and a per-device applied-state table. PASS when the profile is assigned and pilot devices report Succeeded. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. > [CmdletBinding()] param([string]$ProfileName = 'RDP Hardening - Pilot', [string]$GroupId)